

AnkaCORE26

Siber Güvenlik

4. Hafta

İlayda Aytaş

28.02.2026

Bölüm A: Teori ve Mimari (Research & Logic)

1- Web Anatomisi: HTTP Status Kodları

200 OK

İstek başarılıdır. Sunucu kaynağı döndürmüştür.
Pentester için: Endpoint çalışıyor, erişilebilir.

302 Found (Redirect)

Sunucu isteği başka bir adrese yönlendirir.
Pentester için Auth akışını anlamak için önemlidir.

401 Unauthorized

Kimlik doğrulama gerekli veya başarısız.
Pentester için: Bu endpoint auth istiyor. Token/cookie manipülasyonu denenebilir.

403 Forbidden

Sunucu isteği anladı ama erişim vermedi.
Pentester için bu genelde yetki kontrolü var demektir. Rol değiştirme, IDOR, header manipulation gibi testler yapılır.

500 Internal Server Error

Sunucu tarafında hata oluştu.
Pentester için Input ile backend'i kırmış olabiliriz. Stack trace, hata mesajı, teknoloji bilgisi sızabilir.

2. Kimlik ve Yetki

Cookie nedir?

Cookie, tarayıcıda saklanan küçük veri parçasıdır.
Tarayıcı her istekte bu bilgiyi otomatik olarak sunucuya gönderir.

Örnek:

Cookie: session_id=abc123

Cookie bir "taşıyıcıdır". İçinde session ID veya token taşır.

Session nedir?

Session (oturum), **sunucu tarafında** tutulan kullanıcı bilgisidir.

Sistem şöyle çalışır:

1. Login olursun.
2. Sunucu sana bir session ID üretir.
3. Bu ID cookie içine yazılır.
4. Tarayıcı her istekte bu ID'yi gönderir.
5. Sunucu kendi hafızasındaki session kaydına bakar.

Yani veri backend'dedir. Cookie sadece anahtarı taşır.

Bu modele **stateful authentication** denir.

Token nedir?

Token (örneğin JWT), genelde kullanıcı bilgisini içinde taşır.

Login olursun → Sunucu sana imzalı bir token verir.

Bu token:

- user id
- rol
- expiration

gibi bilgileri içerir.

Sunucu her istekte token'ı doğrular ama oturumu bellekte tutmaz.

Bu modele **stateless authentication** denir.

Peki site bizi nasıl "aynı kişi" olarak tanır?

Tarayıcı her HTTP isteğinde:

- Cookie içindeki session ID'yi
veya
- Authorization header içindeki token'ı

tekrar gönderir.

Sunucu bu değeri kontrol ederek:

"Evet, bu daha önce login olmuş kullanıcı." der. Yani sistem bizi IP'den değil, oturum bilgisinden tanır.

Authentication (Kimlik Doğrulama)

"Sen gerçekten söylediğin kişi misin?"

Username + password girersin → sistem doğrular → login olursun.

Yani:

Login olmak = Authentication

Authorization (Yetkilendirme)

"Bu kişi ne yapabilir?"

Admin misin?

Normal kullanıcı mısın?

Sadece kendi verini mi görebilirsin?

Bunlar authorization'dır.

IDOR hangi zafiyet?

Başkalarının mesajlarını okuyabiliyorsan:

- Authentication doğru çalışıyor (login oldun)
- Ama Authorization kontrolü eksik

Yani: **IDOR = Authorization zafiyeti**

3. Zafiyet Mimarisi: IDOR

Kullanıcının eriştiği nesne (object) doğrudan bir ID ile çağrılır ama sistem o nesnenin sahibini kontrol etmez.

/api/messages?id=45

Eğer 46 yazınca başka kullanıcının mesajı geliyorsa → IDOR.

Geliştirici şunu kontrolü yapmayı unutmuştur:

"Bu isteği yapan kullanıcı gerçekten bu kaynağın sahibi mi?"

Sadece şuna bakılmış olabilir:

- Kullanıcı login mi? ✓

Ama şuna bakılmamış:

- Bu kullanıcı bu veriye yetkili mi? ✗

Bu kontrol yapılmazsa IDOR çıkar.

Bölüm B: Saha Eğitimi (TryHackMe & Dorking)

Görev 1: İnternetin Röntgeni (TryHackMe)

Host başlığı, isteğin hangi domain'e gönderildiğini belirtir.

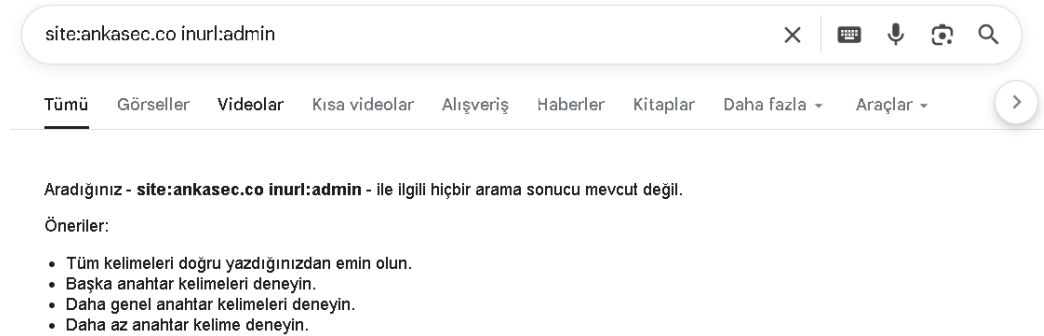
Aynı IP adresinde birden fazla site barınabildiği için (virtual hosting), sunucu doğru siteyi seçmek için Host bilgisini kullanır.

User-Agent başlığı ise isteği gönderen istemcinin (tarayıcı, mobil uygulama vb.) kendini tanıtırma bilgisidir.

Sunucu bu bilgiye bakarak mobil/masaüstü içerik gösterebilir veya uyumluluk ayarı yapabilir.

Görev 2: Google Dorking (Açık Kaynak İstihbaratı)

1-Admin panel aramak için:



`site:ankasec.co inurl:admin`

Bu sorgu, sadece hedef.com domaininde URL içinde "admin" geçen sayfaları arar. Genelde /admin, /admin/login, /administrator gibi yönetim panellerini bulmak için kullanılır.

2- PDF belgeleri bulmak için:

`site:ankasec.co ext:pdf`

Bu sorgu, hedef domainindeki tüm PDF dosyalarını listeler.

Bazen teknik dokümanlar, iç yazışmalar veya yapı bilgileri PDF olarak açıkta kalabilir.

3- Yedek veya hassas dosyaları aramak için:

site:ankasec.co ext:sql OR ext:bak OR ext:env

Bu sorgu, veritabanı yedekleri (.sql), backup dosyaları (.bak) veya environment dosyalarını (.env) arar. Yanlış yapılandırma varsa hassas bilgiler bu dosyalarda bulunabilir.

BÖLÜM C: Operasyonel Görev (Boss Fight)

Cephe 1: Hayalet Avı (Recon Haritası)

```
(kali@kali)~$ subfinder -d prd.services.simplisafe.com -all -recursive -o /home/kali/Desktop/denemesubdomains.txt

projectdiscovery.io

[INF] Current subfinder version v2.12.0 (latest)
[INF] Loading provider config from /home/kali/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for prd.services.simplisafe.com
location-grant-authorizations.prd.services.simplisafe.com
login-devices.prd.services.simplisafe.com
guidepost.prd.services.simplisafe.com
[INF] Found 3 subdomains for prd.services.simplisafe.com in 659 milliseconds 517 microseconds
```

subfinder ile bugcrowd da seçtiğim programın subdomainlerini bulmaya çalıştım ve bir dosyaya kayıttım.

-all → tüm kaynakları kullanır

-recursive → alt alanların altını da arar

-o → dosyaya kaydeder

```
1 |location-grant-authorizations.prd.services.simplisafe.com
2 |login-devices.prd.services.simplisafe.com
3 |guidepost.prd.services.simplisafe.com
4
```

2- httpx aracına vererek hangilerinin "Canlı" (Live) olduğunu kontrol ettim. 2Tane 404 dönen url vardı.

```
(kali@kali)~$ /home/kali/go/bin/httpx -l /home/kali/Desktop/denemesubdomains.txt -status-code -title -o /home/kali/Desktop/liv
e.txt

projectdiscovery.io

[INF] Current httpx version v1.8.1 (latest)
[WARN] UI Dashboard is disabled, Use -dashboard option to enable
https://login-devices.prd.services.simplisafe.com [404]
https://location-grant-authorizations.prd.services.simplisafe.com [404]

(kali@kali)~$
```

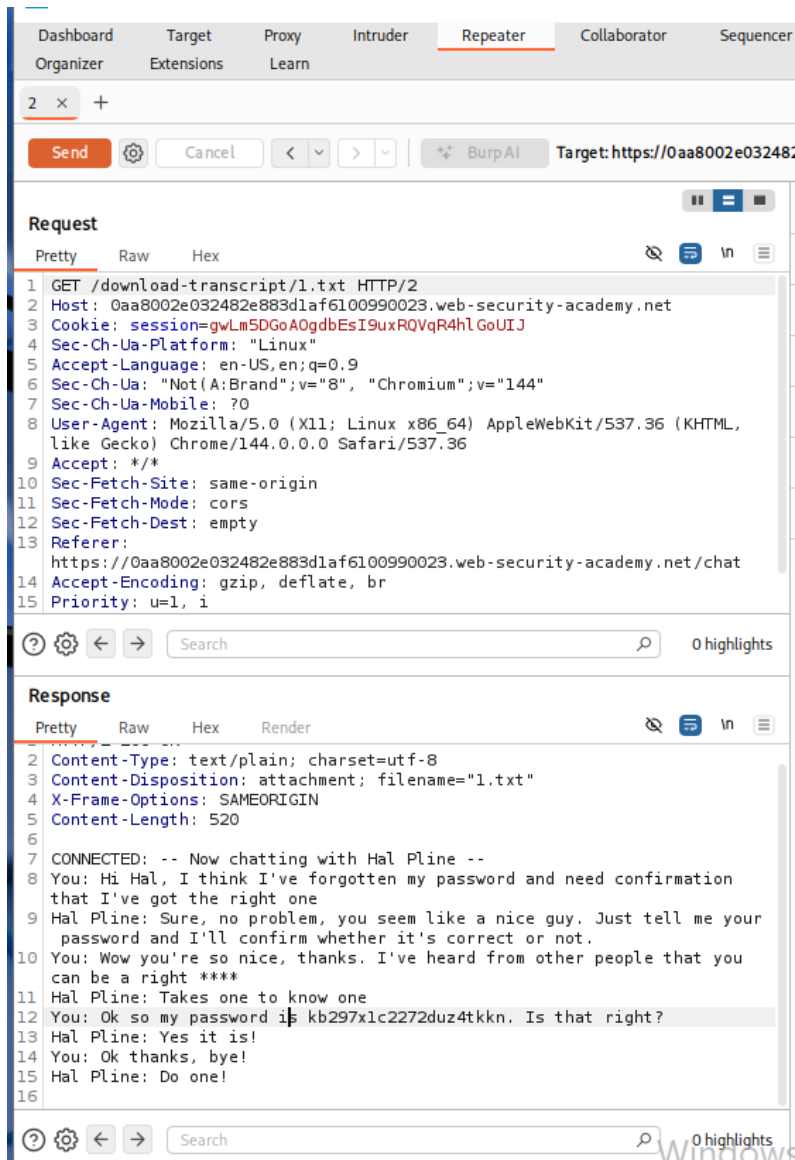
```
~/Desktop/live.txt - Mousepad
File Edit Search View Document Help
1 |https://login-devices.prd.services.simplisafe.com [404]
2 |https://location-grant-authorizations.prd.services.simplisafe.com [404]
3
```

HTTP 404, HTTP 404 - Dosya bulunamıyor, 404 Bulunamadı veya Sayfa bulunamadı hata mesajı, tarayıcının belirli bir sunucuyla iletişim kurabildiğini, ancak sunucunun istenen şeyi bulamadığını belirtmek için bilgisayar ağı iletişimlerinde kullanılan bir Hiper-Metin Transfer Protokolü (HTTP) standart yanıt kodudur.

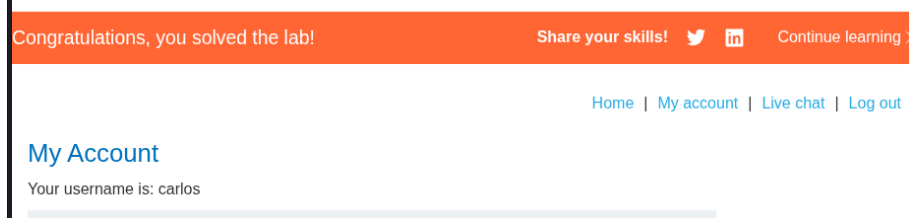
Cephe 2: Yetkiyi Delmek (PortSwigger Labs) Lab: Insecure direct object references

The image shows two side-by-side screenshots. The left screenshot is a web browser displaying the 'Insecure direct object references' lab page from Web Security Academy. The page has a green 'LAB Not solved' badge. The right screenshot is the Burp Suite interface, showing the 'HTTP history' tab with a list of requests. The 'Request' tab is selected, showing a GET request to '/download-transcript/5.txt'. The 'Inspector' tab is also open, showing the request details, including the 'Content-Type: text/plain; charset=utf-8' and 'Content-Disposition: attachment; filename="5.txt"' headers.

View transcript e basınca txt dosyası indiriyor ve bu dosyanın adındaki sayı giderek artıyor ama 1.txt ile başlamıyor 2.txt ile başlıyor. Bu Get isteğini Send to repeater diyip Repeater a gönderip 1.txt olarak değiştiriyoruz txt nin ismini.



1.txt dosyasında password ü görüyoruz.
password is kb297x1c2272duz4tkkn
scarlosun şifresini bul demişti user name de : Carlos



Lab: User ID controlled by request parameter

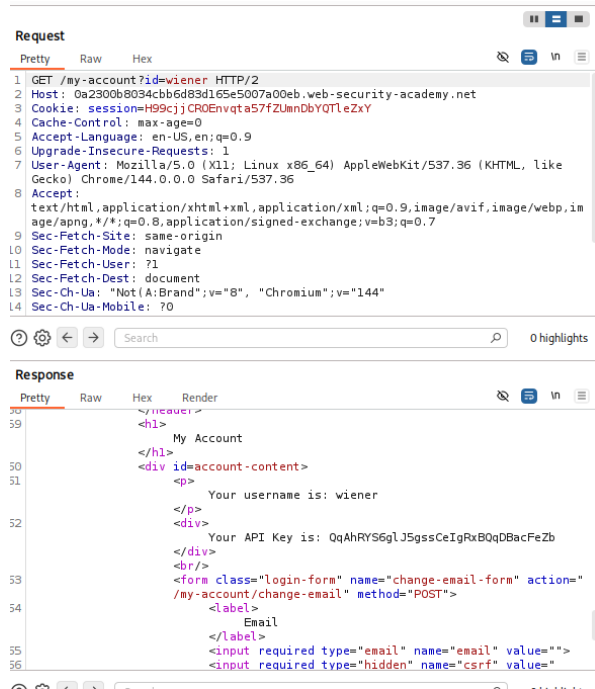
İlk önce oturum açıyorum.

My Account

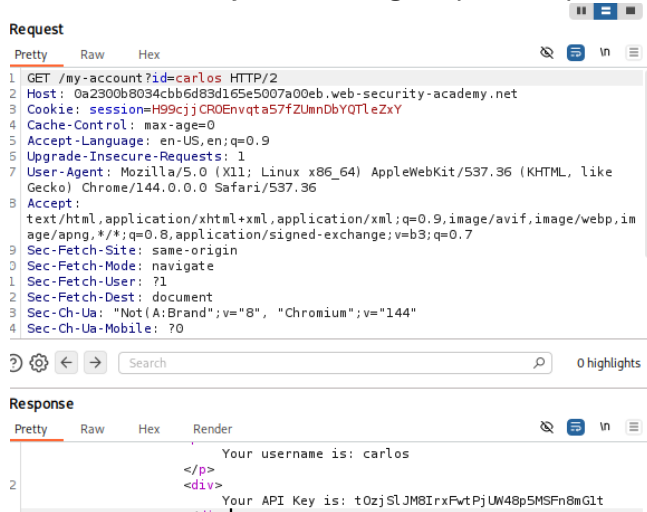
Your username is: wiener

Your API Key is: QqAhRYS6glJ5gssCelgRxBQqDBacFeZb

wiener in API keyi gözüktüyor ve benden Carlos'un ki isteniyor.



Wiener in API keyinin iletildiği requesti repeater da inceliyorum.



Wiener yerine carlos yazınca carlosun api key'ine ulaşıyorum.

Lab: User ID controlled by request parameter

APPRENTICE



Solved

BÖLÜM D: Mühendislik Vizyonu (Reflection)

1- IDOR'un Gerçek Hayat Etkisi

KVKK / GDPR açısından etkisi

- **Kişisel sağlık verisi** çok hassastır (Special Category Data / Sensitive Personal Data).
- Başkasına görünmesi **açık veri ihlali** anlamına gelir.
- **Mali ve hukuki maliyetler:**
 - KVKK/GDPR ihlali cezası: Milyon TL seviyesinde para cezaları (GDPR'da yıllık cirosunun %4'üne kadar).
 - Hasta/müşteri şikayetleri → tazminat talepleri.
- **Marka itibarı:**
 - Güven kaybı, sosyal medyada olumsuz yankı, hasta güveninin sarsılması.
 - “Bu hastaneye veri güvenliği yok” algısı → müşteri kaybı.

Risk Seviyesi (Impact) nasıl açıklanır?

Bir mühendis olarak raporda şöyle yazabilirsiniz:

“Bu IDOR zafiyeti, kullanıcıların yalnızca kendi verilerine erişmesi gerekirken başkalarının **sonuçlarını görmesine izin vermektedir. Bu durum KVKK/GDPR kapsamında ciddi **kişisel veri ihlali** oluşturur. Etki: **Yüksek (High)** — maliyet ve marka itibarı açısından kritik.”

Kısaca: Etki yüksek, çünkü veri hassas ve yanlış erişim ciddi hukuki sonuçlar doğurur.

2- Güvenin Bedeli (Zero Trust)

IDOR ve Broken Access Control'ın temelinde yatan hata:

Kullanıcıdan gelen ID veya veri girişine güvenmek.

Yani URL'de `id=501` yazan kişinin gerçekten o kaynağa yetkisi olup olmadığını kontrol etmemek.

Backend'de yapılması gereken kontrol

1. Sahiplik kontrolü (Ownership Check)

Örnek pseudo-code:

```
# Kullanıcı istekte bulundu
user_id = current_user.id
requested_tahlil = db.get_tahlil(id=requested_id)

# Sahiplik kontrolü
if requested_tahlil.owner_id != user_id:
    return 403 # Forbidden
else:
    return requested_tahlil.data
```

2. Role-Based Access Control (RBAC)

- Farklı roller (hasta, doktor, admin) için ayrı yetkiler tanımlanmalı.
- Her istekte kullanıcının rolü ve erişim izni kontrol edilmeli.

3. Zero Trust Felsefesi

- **Asla kullanıcıya güvenme.**
- Her veri erişiminde kimlik ve yetki doğrulanmalı.
- Sadece backend'e güven, frontend veya URL parametrelerine değil.